

MIDTECH S.A.

Política de Seguridad de la Información

ASISTENTE IA

Nombre: Eduardo Diego Tapia Chavez
Correo: eduardotapiachavez@gmail.com
ID Scola: Ex-1157

índice

Introducción.....	3
FASE 1 – DISEÑO.....	4
1.1 Tecnologías elegidas.....	4
1.2 Objetivos principales.....	4
1.3 Diagramas del sistema.....	4
FASE 2 – RAG.....	6
2.1 Documentos indexados.....	6
2.2 Supabase - Base de datos.....	7
2.3 Funcionamiento.....	7
FASE 3 – CONSTRUCCIÓN DEL ASISTENTE.....	8
3.1 Servidor Virtual Debian.....	8
3.2 Credenciales.....	9
3.3 Base de datos.....	12
3.4 Workflow 1.....	13
3.5 Workflow 2.....	15
FASE 4 – DEMOSTRACIÓN Y CONCLUSIONES.....	17
4.1 Capacidad 1 – Análisis de políticas de seguridad.....	17
4.2 Capacidad 2 – Detección de riesgos e incumplimientos.....	18
4.3 Capacidad 3 – Respuestas a preguntas de auditoria.....	18
4.4 Capacidad 4 – Propuestas de mejora.....	20
4.5 Conclusiones.....	20

Introducción

MIDTECH S.A. es una empresa biotecnológica y farmacéutica con sede en Zaragoza que presta servicios a hospitales públicos y privados. Como empresa del sector salud que trata datos de pacientes y empleados, está sujeta a normativas exigentes como el GDPR, ISO 27001 y el ENS. El problema es que revisar manualmente el cumplimiento de estas normativas contra la política de seguridad interna es un proceso lento, técnico y propenso a errores humanos.

Para este problema se inicio la creación de un asistente interno con una interfaz tipo chat. El asistente está dirigido al responsable de seguridad o auditor interno de MIDTECH, y le permite analizar la política de seguridad, detectar incumplimientos normativos, resolver dudas de auditoría y obtener propuestas de mejora, todo en lenguaje natural y sin necesidad de programar. Aparte debe de hacerlo usando la información mas propia de la empresa y los documentos reales de las diversas normativas.

FASE 1 – DISEÑO

1.1 Tecnologías elegidas

Para la creación del asistente se optó por diversas herramientas enfocadas en IA y automatizaciones en workflows:

- Para la comunicación (LLM): Se usó el modelo de llama-3.1-8b-instant caracterizado por su velocidad y su buen rendimiento en el idioma Español(recordar que la sede es en Zaragoza)

- Para la orquestación: Se decidió por n8n de en su formato local, debido a su costo mensual pero sobretodo a su limite de tokens, lo cual es ilimitado en el formato seleccionado.

- Gestor de documentos: Se selecciono Google Drive por su facilidad de uso, seguridad y sus funciones de API en consola.

- Para poder usar el contenido propio de la empresa (RAG):

 - Embeddings: Se optó por ollama, el modelo nomic-embed-text de forma local.

 - Vector Store: Se usó supabase con pgvector para almacenar los vectores generados.

1.2 Objetivos principales

El asistente debe de tener varias funcionalidades como:

- Análisis de políticas: El técnico podrá pedir un análisis de las políticas que tenga la propia empresa MIDTECH a través de búsqueda de chunks y con el LLM estructurándolo y generando el informe adecuado.

- Gap análisis: Consta de que el técnico podría pedir que detecte incumplimientos de normativa concretos de MIDTECH con respecto a las oficiales (ENS, ISO27001 o RGPD) y viceversa. Esto se puede lograr con el cruce de chunks diferentes de cada documento subido y comparándolos con el LLM.

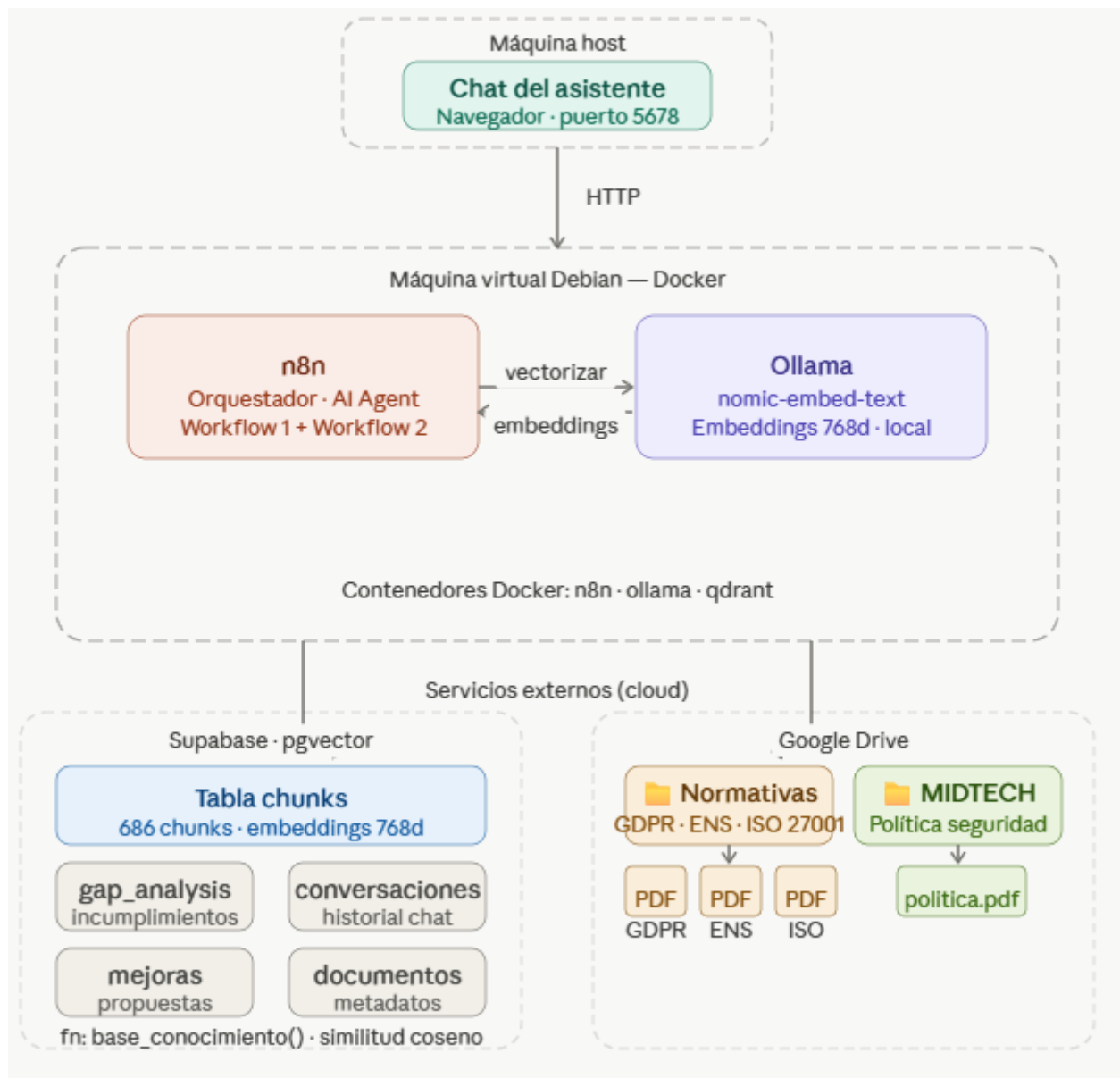
- Auditoria: Si el técnico pregunta otros temas relacionados con los documentos en general. Principal uso del LLM.

- Propuestas de mejora: Tras detectar que políticas fallan o faltan el documento de MIDTECH, el agente podrá generar una lista de mejoras a realizar con un sistema de criticidad para dar mas prioridad a unas con respecto de otras.

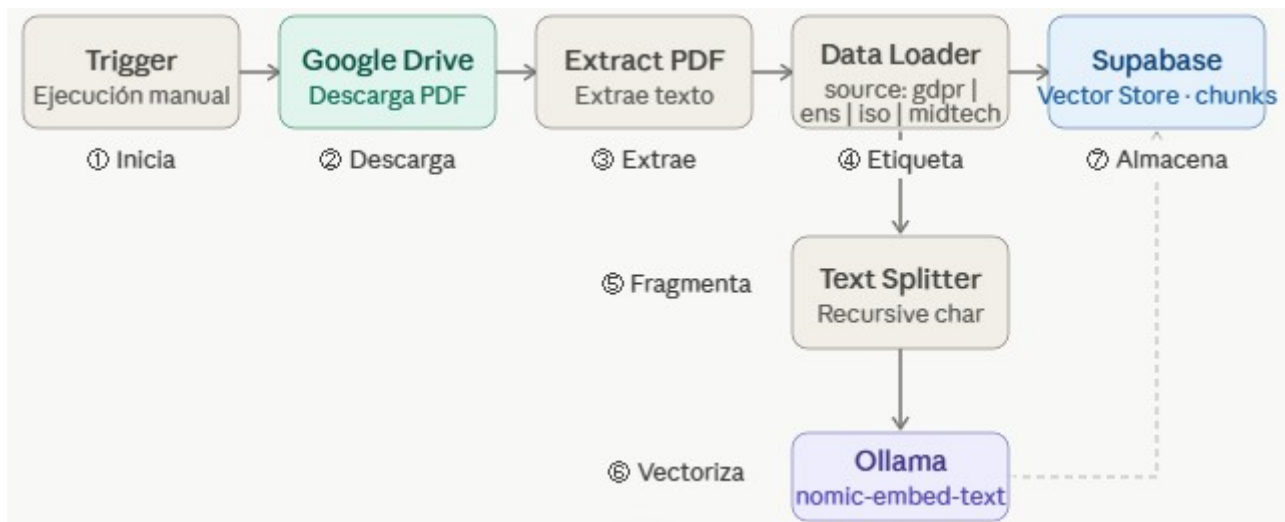
1.3 Diagramas del sistema

En este apartado se busca representar de forma visual y gráfica la infraestructura del proyecto al igual que el funcionamiento de los workflows y agente en si. Por lo que se divide en dos:

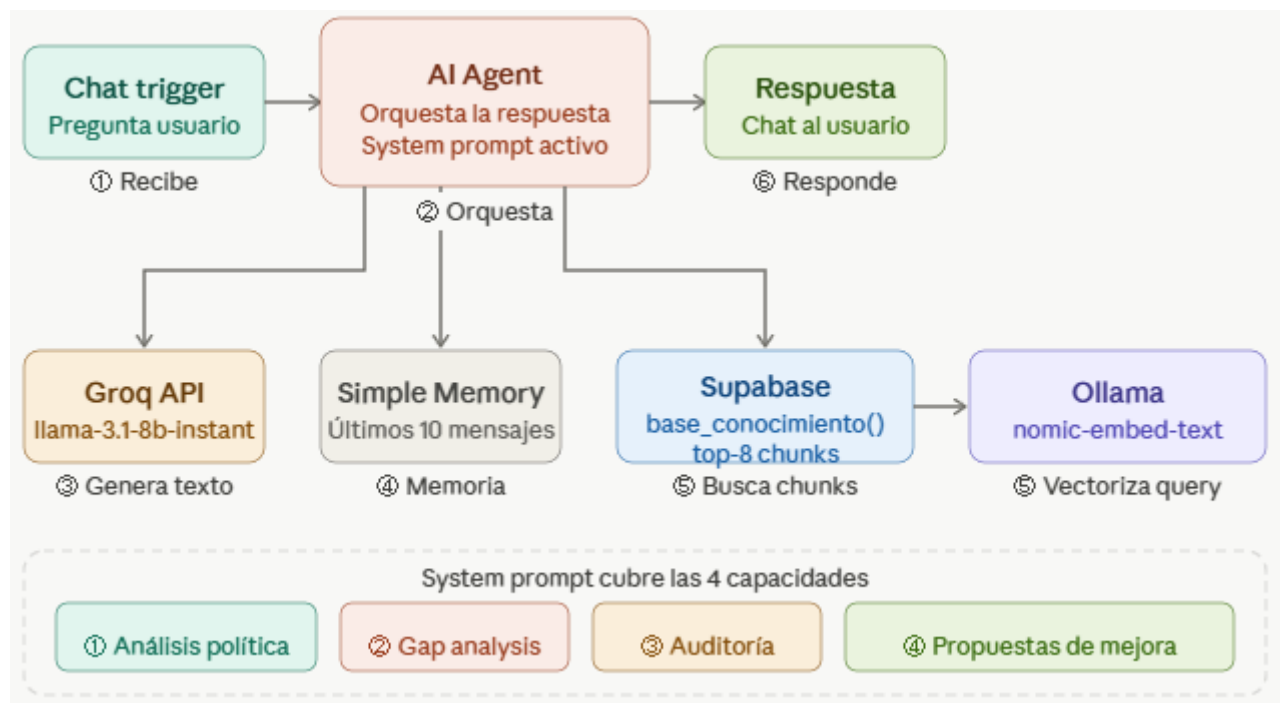
Infraestructura:



Workflow 1 – Subir vectorizados los distintos documentos



-Workflow 2 – Agente IA



FASE 2 – RAG

2.1 Documentos indexados

El sistema RAG permite que modelos LLM tengan acceso a información concreta o privada que previamente en sus entrenamientos no tenían, evitando que “alucinen” o que se lo inventen. De esta forma se pueden crear ayudantes especializados en temas concretos, en este caso se utiliza para el asistente de normativa de MIDTECH, para ello se necesitan los siguientes documentos:

- Políticas de seguridad de Midtech: Se obtuvo directamente, ocupa un espacio de 36 chunks y se reconoce con el metadato source de “midtech” (esta función sirve para saber distinguir los chunks de un archivo con respecto a otro en la misma base de datos)
- Esquema Nacional de Seguridad (ENS): Se obtuvo de la BOE oficial de España, tiene 232 chunks con el metadato source “ens”.
- ISO 27001: No se pudo obtener el oficial completo puesto que es de pago, pero se obtuvo un resumen de 40 chunks con el metadato source “iso27001”.
- GDPR- Reglamento UE: Se extrajo de la web oficial EUR-Lex, tiene 378 chunks con el metadato source “gdpr”

2.2 Supabase - Base de datos

El sitio de estos documentos en formato original, es decir en PDF es en Google Drive en carpetas distintas como se vio en el diagrama de infraestructura. Pero lo que necesitamos son los chunks para que el LLM pueda usarlos. Esta información se almacena en bases de datos, por lo que se optó por usar un servicio en nube que nos proporcione un acceso fácil y estable como lo sería en la plataforma supabase.

El primer workflow se encarga la tarea de enviar los datos en PDF al servidor en formato de chunks con un identificador para saber a que documento pertenece (metadatos).

2.3 Funcionamiento

La información se procesa mediante el siguiente pipeline:

- Descargar desde Google Drive vía nodo de n8n en modo nativo.
- Extraer del PDF el texto con el nodo “Extract from File”.
- Fragmentar el texto extraído para que el modelo pueda vectorizarlo(si es muy grande no puede) con el nodo “Recursive Character Text Splitter”.
- Vectorizar con el modelo ollama en local nomic-embed-text
- Almacenar todos los chunks generados en Supabase en la tabla de chunks con su respectivo metadato.

Tras el almacenado, para extraerlo se realiza una búsqueda semántica con la función “base_conocimiento()” en supabase que calcula similitud entre embedding de la consola y los chunks almacenados.

FASE 3 – CONSTRUCCIÓN DEL ASISTENTE

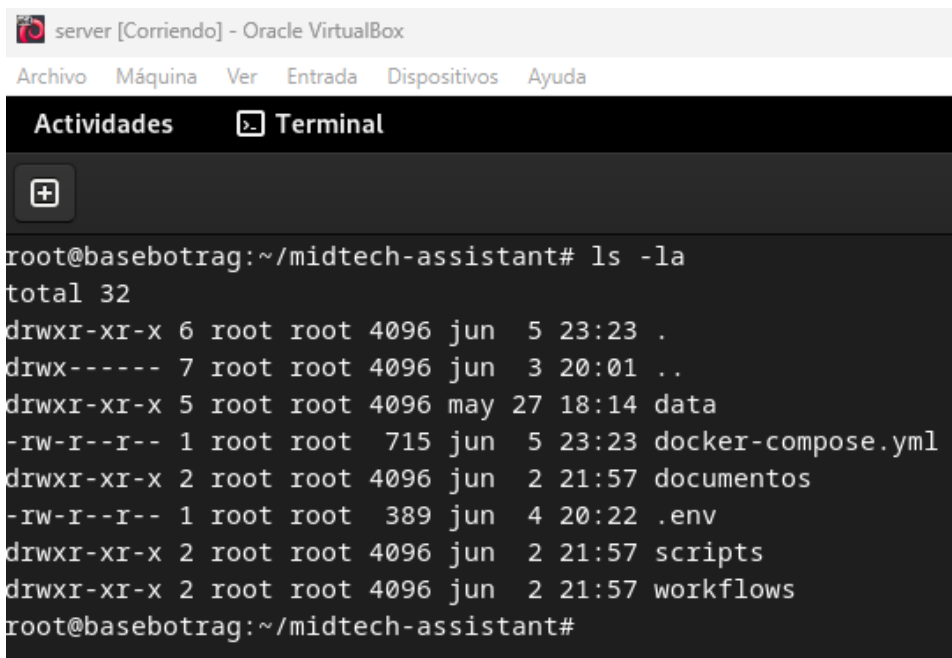
3.1 Servidor Virtual Debian

Tras plantear el diagrama de la infraestructura, se comenzó creando el servidor virtual. Se decidió por este método en vez de usar el servicio cloud que proporciona el propio n8n por 2 razones:

-Costo económico: Se necesita pagar una membresía mensual para poder usar la aplicación en web de forma cómoda o sino una prueba de 15 días con limite de tokens, lo cual se consumieron antes de terminar el proyecto.

-Practicidad: Los objetivos de esta práctica son 3, aprender el uso de herramientas IA, tener un proyecto que mostrar a las empresas para las entrevistas lo cual si caduca en 15 días no se podrá desplegar correctamente y solo se podría enseñar el informe en GitHub, y para uso propio puesto que si se cambia el tipo de pdf y el prompt del asistente debería funcionar como un ayudante experto en muchas áreas. Pero se vuelve al mismo problema, si solo hay 15 días no se podrá usar.

Usando virtualbox como herramienta de virtualización se creo un Linux Debian. Tras las primeras configuraciones del propio server, se descargo mediante linea de comando docker, n8n y ollama embeddings.



```
server [Corriendo] - Oracle VirtualBox
Archivo  Máquina  Ver  Entrada  Dispositivos  Ayuda

Actividades  Terminal

root@basebotrag:~/midtech-assistant# ls -la
total 32
drwxr-xr-x 6 root root 4096 jun  5 23:23 .
drwx----- 7 root root 4096 jun  3 20:01 ..
drwxr-xr-x 5 root root 4096 may 27 18:14 data
-rw-r--r-- 1 root root  715 jun  5 23:23 docker-compose.yml
drwxr-xr-x 2 root root 4096 jun  2 21:57 documentos
-rw-r--r-- 1 root root  389 jun  4 20:22 .env
drwxr-xr-x 2 root root 4096 jun  2 21:57 scripts
drwxr-xr-x 2 root root 4096 jun  2 21:57 workflows
root@basebotrag:~/midtech-assistant#
```

La estructura del docker seria la siguiente:

```
GNU nano 7.2

services:

n8n:
  image: n8nio/n8n:latest
  container_name: n8n
  restart: always
  ports:
    - "5678:5678"
  environment:
    - N8N_HOST=127.0.0.1
    - N8N_PORT=5678
    - N8N_PROTOCOL=http
    - GENERIC_TIMEZONE=Europe/Madrid
    - N8N_SECURE_COOKIE=false
    - GROQ_API_KEY=${GROQ_API_KEY}
    - SUPABASE_URL=${SUPABASE_URL}
    - SUPABASE_KEY=${SUPABASE_KEY}
    - OLLAMA_HOST=${OLLAMA_HOST}
  volumes:
    - ./data/n8n:/home/node/.n8n
    - ./documentos:/documentos
  depends_on:
    - ollama

ollama:
  image: ollama/ollama:latest
  container_name: ollama
  restart: always
  ports:

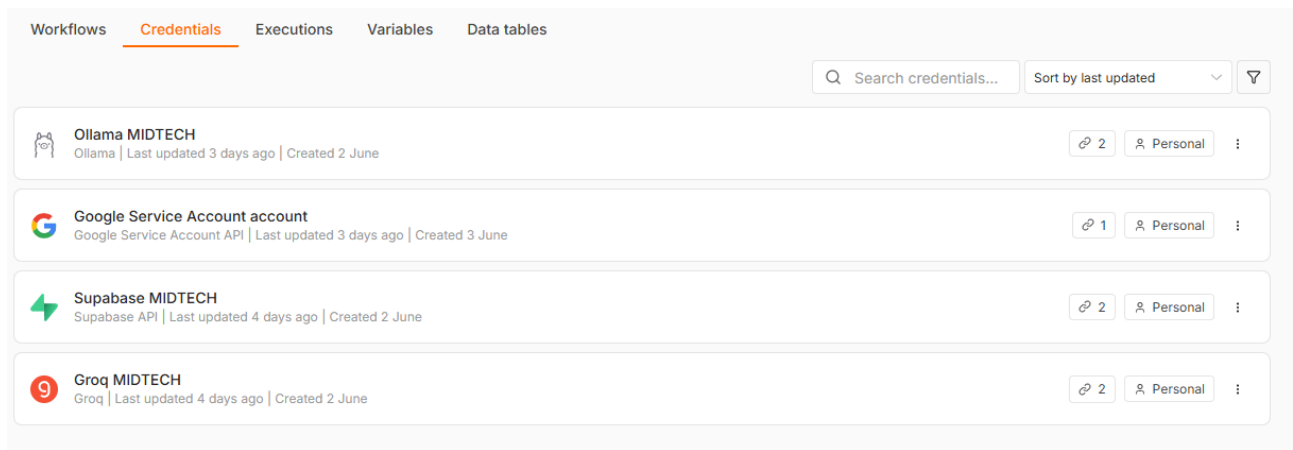
^G Ayuda      ^O Guardar    ^W Buscar
^X Salir      ^R Leer fich. ^\ Reemplazar
```

Docker levantado:

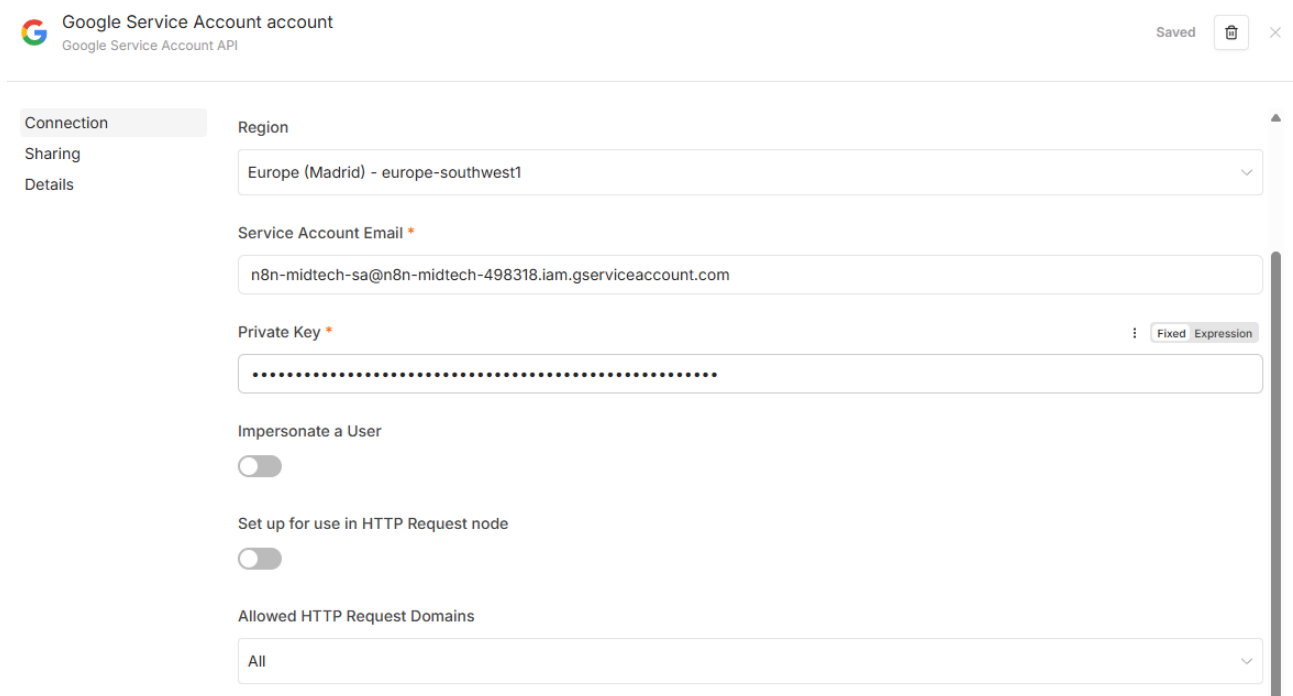
```
diego@basebotrag: ~
root@basebotrag:~/midtech-assistant# docker ps
CONTAINER ID   IMAGE                COMMAND                  CREATED        STATUS        PORTS                                                                 NAMES
d829edc91316   n8nio/n8n:latest     "tini -- /docker-ent..." 44 hours ago   Up 15 minutes   0.0.0.0:5678->5678/tcp, [::]:5678->5678/tcp   n8n
6c7509f8078c   ollama/ollama:latest "/bin/ollama serve"       44 hours ago   Up 15 minutes   0.0.0.0:11434->11434/tcp, [::]:11434->11434/tcp ollama
bd6f9ad0bdd0   qdrant/qdrant:latest ".entrypoint.sh"         11 days ago    Up 15 minutes   0.0.0.0:6333->6333/tcp, [::]:6333->6333/tcp, 6334/tcp qdrant
root@basebotrag:~/midtech-assistant#
```

3.2 Credenciales

Antes de comenzar con los workflows se necesitan las credenciales, ya sean apis o keys de las diversas herramientas cloud que se tiene pensado usar (ver el diagrama de infraestructura):



-Google Drive: Se consigue de la propia consola de Google Cloud, la key esta en JSON y es muy grande.



-Groq: Se busca la página oficial de apis de groq que usa modelos gratuitos de ollama.

Groq MIDTECH

Groq

Saved  

Connection

Sharing

Details

Need help filling out these fields? [Read our docs](#)

 Connection tested successfully

Retry

API Key *

.....

Allowed HTTP Request Domains

All

 Enterprise plan users can pull in credentials from external vaults. [More info](#)

-Ollama embeddings: Esta en formato local instalado en el docker no hace falta una api pero si la url correcta del server local.

Ollama MIDTECH

Ollama

Saved  

Connection

Sharing

Details

Need help filling out these fields? [Read our docs](#)

 Connection tested successfully

Retry

Base URL *

http://ollama:11434

API Key

When using Ollama behind a proxy with authentication (such as Open WebUI), provide the Bearer token/API key here. This is not required for the default Ollama installation

-Supabase: Página web que sirve para alojar la base de datos y genera una url y key para conectarse.

Connection

Sharing

Details

Need help filling out these fields? [Read our docs](#) Connection tested successfully

Retry

Host

<https://ddrpcelqrhdeqktirvgo.supabase.co>

Service Role Secret

.....

Allowed HTTP Request Domains

All

 Enterprise plan users can pull in credentials from external vaults. [More info](#)

3.3 Base de datos

Se creó una base de datos con varias tablas, siendo la de chunks la principal donde se almacenará todos los datos vectorizados.

n8n

<https://ddrpcelqrhdeqktirvgo.supabase.co> 

**STATUS**
Healthy

**COMPUTE**
NANO

**GITHUB**
No repository connected

**RECENT BRANCH**
No branches

**LAST MIGRATION**
No migrations

**LAST BACKUP**
No backups

**Primary Database**
Central EU (Frankfurt)
eu-central-1 · t4g.nano
CPU 2% · Disk 14% · RAM 43% · 5/60 conns

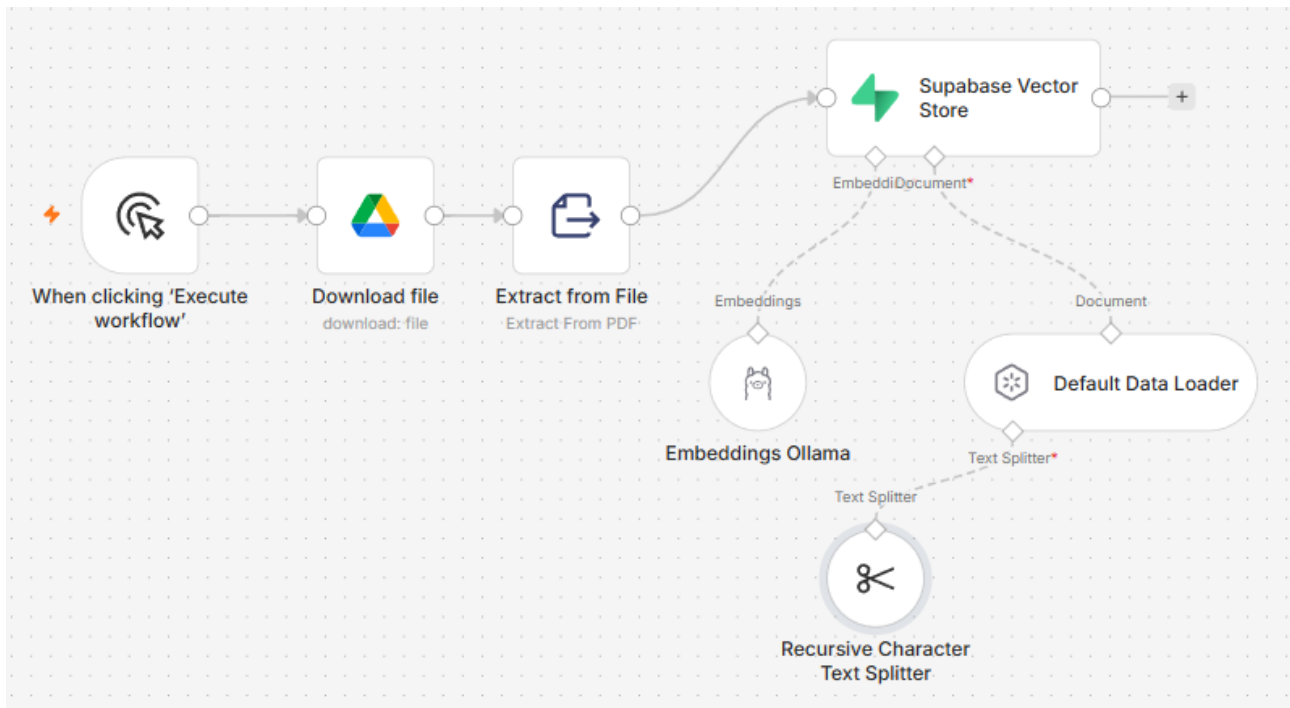
table_name
chunks
conversaciones
documentos
gap_analysis
mejoras

El script de la creación de la base de datos en formato .sql esta en el repositorio de GitHub junto con la función “base_conocimiento()”.

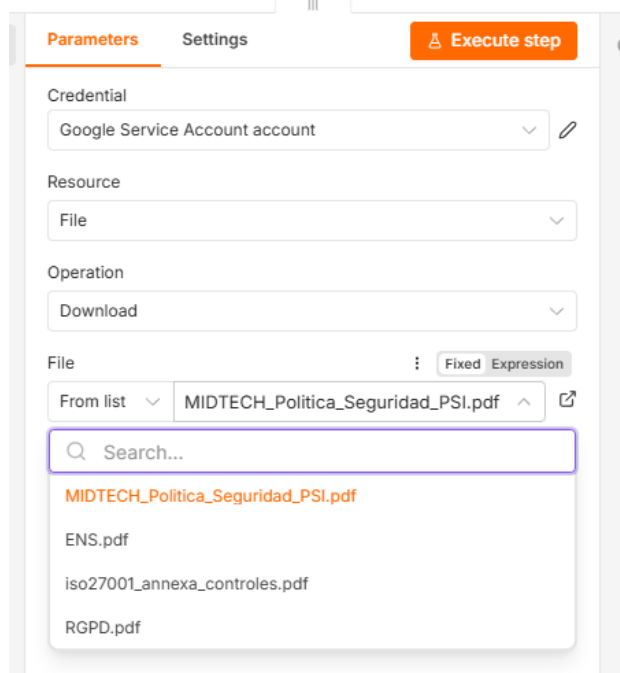
3.4 Workflow 1

Una vez se tienen todas las credenciales, la base de datos montada y lista para recibir información y el docker sin fallos de conexión (tomo mucho tiempo tener todo preparado sin dar fallos).

Creamos el workflow 1 para insertar los chunks:



Se puede seleccionar el archivo concreto en el nodo del drive.



En el nodo de vectorstore se selecciona la tabla objetivo, en este caso chunks.

Parameters Settings **Execute step**

Credential
Supabase MIDTECH

Operation Mode
Insert Documents

Table Name
From list chunks

Embedding Batch Size
200

Options
No properties
Add Option

Dato importante, en el nodo de data loader se debe seleccionar el metadata source correspondiente al archivo que se descarga del drive para generar un identificador para cada chunks y no se mezclen en la base de datos.

Parameters Settings

This will load data from a previous step in the workflow.
Example

Type of Data
JSON

Mode
Load All Input Data

Text Splitting
Custom

Options

Metadata

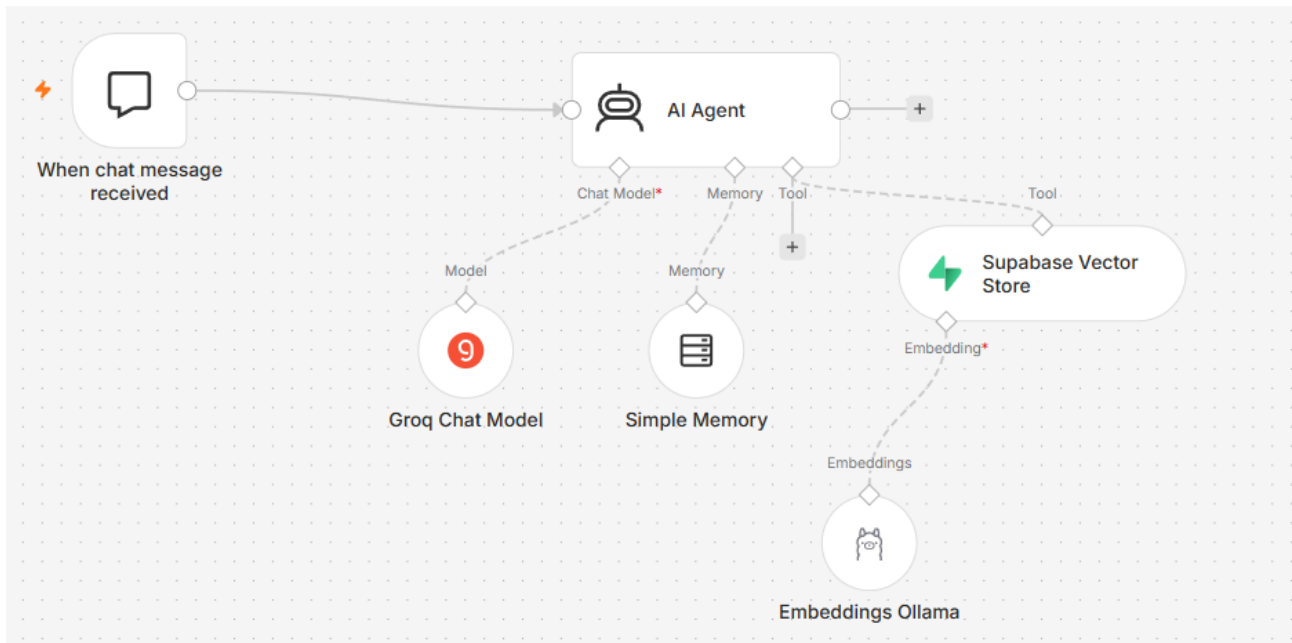
Name
source

Value
midtech

Add property

3.5 Workflow 2

Tras tener todos los chunks guardados en la base de datos, se crea el asistente IA con acceso a esta información.



El AI Agent tiene un prompt largo y muy específico para realizar los 4 objetivos del proyecto. Este prompt se encuentra en el repositorio.

Parameters Settings **Execute step**

Source for Prompt (User Message)
Connected Chat Trigger Node

Prompt (User Message)
`fx {{ $json.chatInput }}`

Require Specific Output Format
☐

Enable Fallback Model
☐

Options

System Message

Eres un asistente experto en ciberseguridad y compliance para MIDTECH S.A., empresa biotecnológica y farmacéutica con sede en Zaragoza que presta servicios a hospitales públicos y privados.

DOCUMENTOS DISPONIBLES:

Add Option

Usa groq como modelo de LLM y una simple memoria puesto que se hacen consultas con gran complejidad de respuesta y no podría almacenar muchos mensajes seguidos.

Cabe resaltar la configuración del nodo vectorstore, concretamente la función “base_conocimiento” que le permite buscar entre chunks dentro de la base de datos.

The image shows the 'Parameters' tab of a configuration interface. At the top, there are two tabs: 'Parameters' (selected) and 'Settings'. To the right of the tabs is an orange button labeled 'Execute step'. Below the tabs, the configuration is organized into sections: 'Credential' with a dropdown menu showing 'Supabase MIDTECH'; 'Operation Mode' with a dropdown menu showing 'Retrieve Documents (As Tool for AI Agent)'; 'Description' with a text area containing 'Busca fragmentos relevantes de la política de seguridad de MIDTECH y de las normativas GDPR, ISO 27001 y ENS'; 'Table Name' with a dropdown menu showing 'From list' and a text field containing 'chunks'; 'Limit' with a text field containing '6'; 'Include Metadata' with a green toggle switch; 'Rerank Results' with a grey toggle switch; and 'Options' with a 'Query Name' text field containing 'base_conocimiento' and an 'Add Option' button.

Toda esta información se muestra en formato de chat, con una url que se proporciona en el nodo chat trigger para usarlo de forma local.

The image shows the 'Parameters' tab of a configuration interface. At the top, there are two tabs: 'Parameters' (selected) and 'Settings'. To the right of the tabs is an orange button labeled 'Open chat'. Below the tabs, the configuration is organized into sections: 'When chat message received' with a speech bubble icon; 'Chat URL' with a text field containing 'http://127.0.0.1:5678/webhook/8249fe77-9975-4cb9-8ac7-a0ecaa71ef70/chat'; and 'Make Chat Publicly Available' with a green toggle switch.

FASE 4 – DEMOSTRACIÓN Y CONCLUSIONES

Hay 2 tipos de demostración, el de capturas de este informe y de videos subidos al repositorio.

4.1 Capacidad 1 – Análisis de políticas de seguridad



← → ↻ 🏠 ⓘ 127.0.0.1:5678/webhook/8249fe77-9975-4cb9-8ac7-a0ecaa71ef70/chat 🔍 ☆ 🔴 🌐 📁 📄 📱 ⋮

Bienvenido al asistente de ciberseguridad de Midtech

Esto es un asistente para auditorías y normativa, cualquier otro uso queda prohibido

Soy el asistente de ciberseguridad y compliance de MIDTECH S.A. Puedo analizar vuestra política de seguridad, detectar incumplimientos normativos, responder preguntas de auditoría y generar propuestas de mejora. ¿En qué puedo ayudarte?

Analiza la política de seguridad de MIDTECH. Dame un informe estructurado con: áreas cubiertas, nivel de cobertura de cada área y áreas ausentes. Cita secciones concretas del documento.

Áreas cubiertas

La política de seguridad de MIDTECH cubre las siguientes áreas:

- Gestión de accesos y autorizaciones (Sección 3.1, "Control de Acceso", source: midtech)
- Protección de datos personales (Sección 4.2, "Protección de Datos Personales", source: midtech)
- Seguridad de la información (Sección 5.1, "Seguridad de la Información", source: midtech)
- Continuidad del negocio (Sección 6.1, "Plan de Continuidad del Negocio", source: midtech)
- Auditoría y revisión (Sección 7.1, "Auditoría y Revisión", source: midtech)

Nivel de cobertura

Para cada área, el nivel de cobertura es el siguiente:

- Gestión de accesos y autorizaciones: parcial. va que se menciona el control de acceso pero no se especifican los procedimientos detallados para la asionación

4.2 Capacidad 2 – Detección de riesgos e incumplimientos

127.0.0.1:5678/webhook/8249fe77-9975-4cb9-8ac7-a0ecaa71ef70/chat

Bienvenido al asistente de ciberseguridad de Midtech

Esto es un asistente para auditorías y normativa, cualquier otro uso queda prohibido

Detecta los incumplimientos normativos de la política de seguridad de MIDTECH respecto al GDPR, ISO 27001 y ENS. Genera un gap analysis completo.

Área normativa: Protección de datos personales Carencia detectada: La política de seguridad de MIDTECH no establece procedimientos específicos para la notificación de violaciones de datos personales en un plazo de 72 horas (Sección 4.2, "Protección de Datos Personales", source: midtech) Criticidad: Alto Referencia normativa: GDPR Art. 33, "Notificación de violaciones de datos personales" (source: gdpr)

Área normativa: Gestión de accesos y autorizaciones Carencia detectada: La política de seguridad de MIDTECH no establece procedimientos detallados para la asignación y revocación de permisos de acceso a datos personales (Sección 3.1, "Control de Acceso", source: midtech) Criticidad: Medio Referencia normativa: GDPR Art. 32, "Seguridad del tratamiento" (source: gdpr)

Área normativa: Seguridad de la información Carencia detectada: La política de seguridad de MIDTECH no establece medidas de seguridad específicas para la protección de la información, como la autenticación de dos factores o la cifrado de datos (Sección 5.1, "Seguridad de la Información", source: midtech) Criticidad: Medio Referencia normativa: ISO 27001 A.8.1, "Gestión de Riesgos" (source: iso27001)

Área normativa: Continuidad del negocio Carencia detectada: La política de seguridad de MIDTECH no establece un plan de continuidad del negocio detallado y completo (Sección 6.1, "Plan de Continuidad del Negocio", source: midtech) Criticidad: Bajo Referencia normativa: ISO 27001 A.17.1, "Continuidad del negocio" (source: iso27001)

Área normativa: Seguridad de la infraestructura Carencia detectada: La política de seguridad de MIDTECH no establece medidas de seguridad específicas para la protección de la infraestructura, como la seguridad de los servidores o la red (Sección 5.1, "Seguridad de la Información", source: midtech) Criticidad: Alto Referencia normativa: ENS mp.s.1, "Seguridad de la Infraestructura" (source: ens)

Área normativa: Gestión de riesgos Carencia detectada: La política de seguridad de MIDTECH no establece un proceso de gestión de riesgos detallado y completo (Sección 3.1, "Control de Acceso", source: midtech) Criticidad: Medio Referencia normativa: ISO 27001 A.8.1, "Gestión de Riesgos" (source: iso27001)

4.3 Capacidad 3 – Respuestas a preguntas de auditoría

Esto es un asistente para auditorias y normativa, cualquier otro uso queda prohibido

Para determinar si MIDTECH cumple con el artículo 32 del GDPR, debemos analizar la política de seguridad de la empresa y compararla con los requisitos establecidos en el artículo 32.

- La seudonimización y el cifrado de los datos personales
- La capacidad de garantizar la confidencialidad, integridad y disponibilidad de los datos personales
- La capacidad de restaurar la disponibilidad y el acceso a los datos personales en caso de un incidente de seguridad
- La evaluación regular y la actualización de las medidas de seguridad

Además, la política de seguridad de MIDTECH no establece procedimientos detallados para la evaluación regular y la actualización de las medidas de seguridad, lo que es un requisito establecido en el artículo 32 del GDPR.

Type your question..

4.4 Capacidad 4 – Propuestas de mejora



4.5 Conclusiones

El asistente construido para MIDTECH S.A. demuestra que es posible desarrollar un sistema de análisis de ciberseguridad y compliance completamente funcional combinando herramientas gratuitas y de código abierto. A lo largo del proyecto se han integrado con éxito n8n como orquestador visual, Ollama para la generación de embeddings locales, Groq como modelo de lenguaje, Supabase como base de datos vectorial y Google Drive como gestor documental. El resultado es un asistente que cubre las cuatro capacidades requeridas, produce respuestas específicas para MIDTECH citando siempre las fuentes documentales concretas, y es capaz de cruzar la política interna de la empresa con las normativas GDPR, ISO 27001 y ENS de forma conversacional y sin necesidad de programar.

Durante el desarrollo se tomaron decisiones técnicas conscientes orientadas a garantizar que el proyecto fuera completable en el tiempo disponible. La base de datos diseñada en Supabase incluye tablas adicionales — conversaciones, gap_analysis, mejoras y documentos — que no se llegaron a integrar en el flujo del asistente pero que representan la arquitectura completa de un sistema profesional real. La tabla gap_analysis habría permitido persistir cada incumplimiento detectado como registro estructurado en base de datos, posibilitando consultas históricas sobre los análisis realizados. La tabla mejoras habría almacenado las propuestas generadas para poder recuperarlas y

compararlas entre sesiones. La tabla conversaciones habría dado al asistente memoria persistente entre sesiones, convirtiendo el historial de auditoría en un activo consultable. La tabla documentos habría registrado los metadatos de cada PDF indexado, aportando trazabilidad completa sobre qué normativas están disponibles y cuándo fueron cargadas.

A pesar de estas limitaciones de alcance, el sistema funciona correctamente como prueba de concepto y cumple los criterios de calidad establecidos en la rúbrica. Las principales limitaciones técnicas identificadas son el rate limit de Groq en capa gratuita, que condiciona el uso intensivo del asistente en sesiones largas, y el volumen reducido de chunks indexados para ISO 27001 al haber utilizado un resumen en lugar del estándar completo. Con más tiempo, las mejoras prioritarias serían implementar el guardado automático del gap analysis en Supabase, indexar el estándar completo de ISO 27001, y añadir autenticación a la interfaz de chat para proteger el acceso. En general se ha aprendido mucho en la elaboración del proyecto, si es en formato local es verdaderamente útil más allá de esta practica pues la IA es un herramienta poderosa que hay que saber usar.